PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Cybersécurité des start-up et failles IDOR

03-1090 ANSSI - Cybersécurité des start-up du numérique et protection contre les failles IDOR — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Les jeunes et petites entreprises sont les plus touchées par les compromissions et rançongiciels.
2. La génération de SBOM doit être effectuée à chaque construction et complétée par une analyse SCA.
3. L'IDOR occupe la première place du Top 10 OWASP 2025 et nécessite un contrôle d'autorisation obligatoire côté serveur.

Synthèse du guide des start-up

Notion	À retenir
Contexte	Cible : start-up (produit logiciel, équipes restreintes). Atteintes numériques : **+74 %** en 5 ans, **>17 100** cas en 2024. **13 enjeux** de sécurité.
Savoir-faire et postes	Chiffrer les données sensibles avant envoi, sauvegarder **au moins 1 fois/mois** hors ligne, revoir les droits **tous les 6 mois**. Gestionnaire de mots de passe ; verrouillage session : **5 min max**. Pas de privilèges admin local.
Réglementation et tiers	Réglementations : **NIS 2**, **RGPD**, **HDS**, **IA Act**, **Cyber Resilience Act**, **DORA**. **SBOM** à chaque construction + analyse **SCA**. Ne **jamais réimplémenter la cryptographie** ; prévoir la réversibilité.
Développement et déploiement	Pas de secrets en clair en dev. Signer les commits, relecture par pair, utiliser **SAST**, **SCA**, gestion secrets, puis **DAST**. Limiter comptes admin humains.
Valorisation et passage à l'échelle	Publier `security.txt` et `security.md`. Industrialisation : limiter les versions, transparence sur les vulnérabilités, prévenir l'ANSSI via le **CERT-FR**. Échelle : poste **RSSI**, **PCA**, **PRA** et plan de réponse aux incidents.
Hébergement et levée de fonds	Données critiques : privilégier **SecNumCloud**. Levée de fonds : infos non sensibles dans le **pitch deck**, accords de confidentialité et data room chez fournisseur de confiance.

Protection contre les failles IDOR

Notion	À retenir
Faille critique	Touche applications **web**, **API** (mobile, natives, IA). **1ère place** du **Top 10 OWASP 2025**. Sous-types : **BFLA** (fonction), **BOLA** (objet), **BOPLA** (propriété). Permet récupération massive d'infos ou action pour autrui.
Dès la conception	Vérifier l'**autorisation** (l'authentification ne suffit pas). Contrôle **côté serveur** obligatoire. Revue de code par les pairs et tests des **cas non passants** (utilisateur B refusé sur ressources de A).
Cycle de vie et production	Automatiser via **SAST** puis **DAST** dans la **CI/CD**. Tests d'intrusion et **bug bounty**. Détecter les pics d'utilisation (IP ou compte) type **énumération séquentielle**. Bloquer IP/compte en cas d'attaque.

Pièges et confusions

- ⚠ Croire que l'authentification remplace le contrôle d'autorisation côté serveur
- ⚠ Réimplémenter soi-même la cryptographie
- ⚠ Croire que les jeunes et petites entreprises sont épargnées : ce sont les plus touchées par les rançongiciels.
- ⚠ Oublier que l'IDOR est la première vulnérabilité du Top 10 OWASP 2025

Sigles et définitions

IDOR	vulnérabilité due à un manque de vérification côté serveur de l'autorisation d'accès d'un utilisateur à une ressource
SBOM	nomenclature des composants logiciels d'un produit
SCA	analyse qui identifie les vulnérabilités et licences des composants tiers
SAST	analyse statique de code examinant le code source au plus tôt
DAST	analyse dynamique qui teste l'application déployée
IaC	infrastructure décrite et déployée par du code et des fichiers de configuration
NHI	comptes techniques utilisés par les automatismes de déploiement
CVD	organisation du signalement des failles par des tiers

Auto-test

1. Quelle est la place de l'IDOR dans le Top 10 OWASP 2025 ?
2. À quelle fréquence faut-il sauvegarder les données hors ligne ?
3. Quel type de cloud privilégier pour les données critiques ?
4. Quelle est la durée maximale recommandée pour le verrouillage de session ?
5. Que signifie l'acronyme BFLA ?

Réponses : **1.** 1ère · **2.** Au moins une fois par mois · **3.** SecNumCloud · **4.** 5 min max · **5.** Droit d'accès à une fonction

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.